

Blog on GRC Practices and Market trends

Author: Prof. Hernan Huwyler, MBA CPA

Run Risk Quantification Outside Your GRC Platform, Not Inside It

GRC platforms like ServiceNow, Archer, or SAP GRC are designed to capture evidence and close audit findings, not to model uncertainty or inform capital decisions. The most consequential shift a risk professional can make right now is separating the workflow tool from the analytical engine. Run Monte Carlo simulations, probability distributions, and sensitivity analysis in Python or R, then feed conclusions back into the GRC platform for documentation. This architecture gives you audit trail compliance without sacrificing analytical depth. In large global companies, risk functions that produce defensible quantitative outputs, loss exceedance curves, VaR percentiles, expected annual loss in currency, command board attention in ways that heat maps never will. As AI increasingly automates the evidence-collection layer inside GRC platforms, the professionals who own the quantitative modeling layer will hold the highest-leverage positions in the risk function. Build that skill now, before it becomes a hiring prerequisite rather than a differentiator.

Fix Segregation of Duties Before Migration, Not After the Audit

Every SAP S/4HANA migration inherits the access conflicts of the system it replaces, and then amplifies them through role redesign, Fiori interface changes, and new authorization objects that map imperfectly to legacy PFCG roles. The remediation workflow is concrete: use SUIM to identify users with conflicting transaction combinations, SU24 to review authorization object assignments at the transaction level, and PFCG to rebuild roles with least-privilege principles before go-live. The audit bill for fixing this post-migration is consistently higher than the project cost of fixing it pre-migration, because post-go-live remediation requires production access freezes, compensating control documentation, and often external forensic review. Risk managers and internal auditors who can lead this remediation workflow, not just flag the findings, are genuinely rare in large enterprise environments. AI-assisted role mining tools are emerging to accelerate conflict detection, but the judgment about which conflicts are material and which are theoretical still requires human expertise with both the business process and the authorization model.

Treat Probability as Mathematics

The most quietly dangerous practice in enterprise risk management is multiplying two probability estimates together without testing the independence assumption first. If two risk events share a common cause, the same vendor, the same control failure, the same macroeconomic condition, their joint probability is not the product of their individual probabilities. Treating correlated risks as independent can understate combined exposure by 4x or more, which means contingency reserves are systematically too low and boards are systematically misinformed. The practical fix is to work explicitly with probability density functions and cumulative distribution functions rather than point estimates, use conditional probability where dependency exists, and document the independence assumption whenever you multiply. This applies directly to compliance risk portfolios, cyber incident modeling, operational risk capital, and third-party concentration analysis. In global companies where risk aggregation across business units and geographies is a regulatory expectation, under Basel, Solvency II, or internal capital adequacy frameworks, professionals who can build and defend these models are operating at a level of analytical rigor that qualitative risk managers cannot match.

Audit SAP HR and Payroll at the Transaction Code Level, Not the Report Level

Most SAP HR audits review output reports that the auditee selects and formats. The risk this misses is self-access: HR administrators who can view or modify their own personnel records, payroll parameters, or time management entries without triggering a segregation of duties conflict because the conflict exists within a single role rather than across two. Effective SAP HCM auditing requires direct transaction-level navigation — pulling infotype change logs, reviewing PA30 and PA40 access against user master records, testing payroll schema configuration in PE01 and PE02, and verifying time management authorizations in PT60 and PT_DOC00. The same principle applies to SAP FI tax configuration: the tax engine is jurisdiction-sensitive, table-driven, and rarely reviewed at the configuration level during standard SOX testing. Auditors who can navigate SAP directly, without depending on data extracts provided by the auditee, eliminate a fundamental information asymmetry that sophisticated fraud schemes specifically exploit. As AI-assisted audit tools begin automating standard report-level testing, the auditors who understand the underlying system architecture will supervise those tools rather than be replaced by them.

Reframe ERM Around Opportunity Capture, Not Only Downside Defense

The dominant mental model in enterprise risk management treats risk as something to reduce, transfer, or avoid. This framing systematically undervalues the upside, the

strategic options, competitive positions, and investment returns that only become accessible by accepting well-understood risk. Connecting Porter's Five Forces competitive analysis to formal ERM methodology reframes the risk function as a strategic advisor rather than a compliance monitor. Dynamic risk visualization — showing how risk positions evolve over time rather than presenting a static heat map — gives boards the temporal context they need to make capital allocation decisions, not just governance decisions. Culture determines whether this reframing sticks: an organization can build sophisticated ERM infrastructure and still produce unread documentation if leadership treats risk management as a reporting obligation rather than a decision-support function. Risk professionals who can make this cultural and analytical shift — speaking the language of opportunity-adjusted return rather than control deficiency — will occupy the advisory positions that survive automation. The professionals who remain anchored to downside-only, documentation-heavy risk work will find that AI absorbs most of what they currently do within this decade.

#	Date	Article	Why it's worth reading
1	Jul 2026	Stop Chasing Evidence to Start Informing Decision-Making	Argues GRC platforms are built for audit trails, not analysis, and makes the case for running risk quantification in Python or R alongside the workflow tool instead of inside it.
2	Jul 2026	AI Isn't Coming For GRC Jobs. It's Coming For The Manual Review Part Of Every GRC Job	Breaks down what's actually left for risk, compliance, audit, cyber, controller, and sustainability professionals once AI absorbs the manual review work each role was built around.
3	Jul 2026	Probability Is Not Intuition, A Quantitative Risk Framework Every Risk Manager Must Own	A technical walkthrough of PDFs, CDFs, conditional probability, and independence assumptions, anchored in a real case where multiplying two probabilities together silently understated risk by 4x.
4	Jul 2026	S/4HANA Role Redesign: Fix Segregation of Duties Before Go-Live or Pay the Audit Bill After	A step-by-step SUIM-SU24-PFCG remediation workflow for fixing SAP access conflicts before an S/4HANA migration inherits and amplifies them.

#	Date	Article	Why it's worth reading
5	May 2026	A Practical Field Guide for Auditing SAP HR Systems	Transaction-code-level guidance for auditing SAP HCM across personnel data, payroll, and time management, including the self-access risks most reviews miss.
6	Jan 2009	Compliance as a Global Corporate Concern	An early read on cross-border compliance and mega-fine exposure, written just as the FCPA and OFAC enforcement era was taking shape.
7	Jan 2009	Compliance Risk Assessments	A step-by-step methodology for enterprise-wide compliance risk assessment aligned to ISO 31000 and COSO ERM.
8	Jan 2009	Useful SAP T-Code List for Auditing	A working reference of SAP transaction codes auditors need to navigate the system directly instead of relying on data the auditee chooses to hand over.
9	Jan 2009	Business Fraud Risks and Economic Compliance	Fraud triangle analysis and economic compliance written at the height of the 2008-2009 financial crisis, when white-collar enforcement was about to surge.
10	Feb 2009	Value of an Active FCPA Compliance Program	Makes the case that a documented, active FCPA program reduces penalties and can earn a declination, not just satisfy a checkbox.
11	Feb 2009	Audit Risks and Objectives for 2009	Covers liquidity, credit, and going-concern risk auditing during an economic downturn, themes that resurface every time rates or credit conditions tighten.
12	Feb 2009	Challenges for Operational Risk	A people-process-technology taxonomy for operational risk, from a period before major banking operational risk capital reforms formalized the same categories.

#	Date	Article	Why it's worth reading
13	Feb 2009	Offshoring Finance Activities	A case study on offshoring finance and shared services, covering the internal control issues, transfer pricing and segregation of duties, that don't disappear just because the work moved.
14	Jun 2011	SAP and Business Cycle Controls for SOX	Maps SAP's automated Procure-to-Pay, Order-to-Cash, and Record-to-Report controls directly to SOX 404 testing requirements.
15	Jun 2011	How Taxes Are Computed by SAP FI AP/AR	A technical breakdown of SAP's configurable tax engine, the specific tables to pull, and why tax setup is one of the most jurisdiction-sensitive areas to audit.
16	Jun 2011	Collusive Fraud Schemes and Controls	On why collusive fraud defeats segregation of duties specifically, and what forensic and whistleblower controls actually catch it.
17	Jun 2011	Audit Procedures for FCPA Testing	Concrete testing steps for FCPA compliance: travel and entertainment analytics, vendor master reviews, gifts and hospitality registers.
18	Jun 2011	Do All Failed SOX Controls Have to Be Reported?	Clarifies the actual threshold distinguishing a deficiency from a material weakness, a judgment call with no single statutory definition.
19	Jun 2011	Strategic Risk Management	Connects competitive intelligence tools like Porter's Five Forces to formal ERM methodology for risks that threaten strategy execution itself.
20	Jun 2011	Success Factors in Risk Management	On how culture determines whether controls function as designed or exist only as unread documentation.
21	Jun 2011	Automation for GRM Management	An early, ahead-of-its-time case for continuous control monitoring and continuous auditing technology.

#	Date	Article	Why it's worth reading
22	Jun 2011	Motion Charts and Dynamic Risk Maps	Introduces dynamic, time-based risk visualization for boards a decade before it became a standard dashboard feature.
23	Jun 2011	New Variables in Risk Measurement	Brings macro-factor correlation and tail-risk measurement into ERM models that were still mostly qualitative at the time.
24	Jun 2011	Personal MBA by Josh Kaufman (Review)	A management-education book review connecting Kaufman's mental models to systems thinking and decision-making under uncertainty.
25	Jul 2011	Simple Tool to Identify Risks	A lightweight, accessible risk-identification tool built for operational managers rather than dedicated statisticians.
26	Aug 2011	Defining GRC Culture	Distinguishes GRC infrastructure from GRC culture, and argues an organization can't expect compliant behavior without funding the tools that make it possible.
27	Aug 2011	Enterprise Opportunity Management and ERM	Reframes ERM around upside risk and opportunity capture, not only downside defense.

#	Date	Article	Why it's worth reading
1	Jul 2026	Future of Corporate Governance: A Masterclass in GRC, SAP Audit, and AI Risk	Functions as a curated index in its own right, organizing 20 of his older Blogger essays by theme alongside his book and full credential background.
2	Apr 13, 2026	Why I Write About AI Governance (And Why It Actually Matters)	His stated rationale for the whole body of AI governance writing, cross-posted the same day to DEV under the identical title.

#	Date	Article	Why it's worth reading
3	Mar 2, 2026	Stop Using High/Medium/Low Charts for AI Risk	Built around a specific IT architecture committee moment, argues for a 9-domain framework in place of ordinal risk heat maps.

#	Date	Article	Why it's worth reading
1	Jul 22, 2026	The AI Layoff Story Is Wrong, and It's Sidelining GRC Professionals	Reframes AI-driven headcount cuts as a control-architecture problem, with a concrete case of a password-reset automation whose control silently disappeared for eighteen months.

#	Date	Article	Why it's worth reading
1	Jul 29, 2026	From AI Hype to AI Accountability - AI Engineering Summit	A long-form summit-style piece on AI threats, risks, and vulnerability, tagged for a developer audience.
2	Apr 30, 2026	Why Traditional Security Testing Misses 70% of AI Attack Surface	Argues standard penetration testing and access reviews leave most of an AI system's actual attack surface unchecked.
3	Apr 13, 2026	Practical Problem Definition for AI Projects (A Developer-First Guide)	The engineering-facing version of his use-case-definition framework, aimed at developers rather than governance teams.
4	Apr 13, 2026	Build vs Buy for AI Systems (A Developer's Guide to Not Regretting the Decision)	Four lenses, solution fit, latency and compliance boundaries, behavioral constraints, and integration depth, for deciding whether to build, buy, or hybridize an AI system.
5	Apr 13, 2026	The 10 Engineering Practices That Separate Production AI	A developer-facing companion to his AI project management writing, focused on

#	Date	Article	Why it's worth reading
		Systems From Science Projects	what actually changes between a notebook prototype and a production system.
Apr 6 13, 2026		Why I Write About AI Governance (And Why It Actually Matters)	Same title and theme as the Medium post above, published the same day, aimed at a developer readership instead.